

SprawlBlock: Enterprise IAM Privilege Sprawl & Threat Detection System

Comprehensive System Architecture & Analysis Algorithms Specification

SprawlBlock is a premium, enterprise-grade identity risk analytics platform designed to solve **Problem Statement 4 (IAM Privilege Sprawl and Threat Detection)**. The system ingests disparate identity data, group memberships, and platform-specific audit events to build a unified, multi-platform Entitlement Graph. It applies a hybrid anomaly detection pipeline—combining structural graph traversal, machine learning (Isolation Forest), and deterministic rule matches—to surface, cluster, and remediate compliance and security risks.

1. High-Level System Architecture

SprawlBlock is built on a decoupled, modular pipeline running on a lightweight Python/Flask backend and a dynamic Vanilla HTML5/CSS3/JavaScript frontend.

Data Flow Diagram

The system operates as an Identity Threat Detection and Response (ITDR) platform. It is designed to map complex, multi-platform Identity and Access Management (IAM) environments (specifically Active Directory, AWS, and Okta), calculate hybrid risk scores, and provide actionable remediation paths.

1. Data Ingestion & State Generation

The pipeline begins at the data layer, handled by `simulate_data.py`. Since live production IAM data is highly sensitive, the system relies on a synthetic generation engine to create a realistic corporate environment.

- **Outputs:** Generates structured datasets (`identities.csv`, `permissions.csv`, `group_mappings.csv`, `audit_events.csv`).
- **Mechanism:** It maps out human identities and assigns them varying levels of platform accounts, group bindings, and terminal permissions. It intentionally injects

anomalies—such as excessive privilege-to-usage ratios, dormant accounts, or cross-platform segregation of duties (SoD) violations—to act as targets for the detection engine.

2. Graph Construction & Feature Extraction

Tabular IAM data is difficult to analyze for transitive risks. `graph_engine.py` converts the relational CSV data into a mathematical graph.

- **Entitlement Graph:** Builds a directed network where nodes are entities (Identities, Accounts, Groups, Permissions) and edges represent the flow of access (e.g., *Identity -> Maps To -> AWS Account -> Belongs To -> Admin Group -> Has -> S3 Full Access*).
- **Feature Matrix Generation:** The engine parses the graph to extract mathematical features for each identity. Metrics include `access_frequency`, `platform_spread`, `privilege_to_usage_ratio`, and `total_privileges`.

3. Dual-Engine Risk Scoring

The `risk_scorer.py` module takes the feature matrix and graph data to evaluate the security posture of every identity using a hybrid approach.

- **ML Risk Score:** Uses unsupervised machine learning (specifically an Isolation Forest algorithm, as referenced in the frontend simulation reset logic) to detect behavioral anomalies. It flags users whose access patterns mathematically deviate from their departmental peers.
- **Deterministic Violations:** Runs hardcoded compliance queries against the graph to catch blatant architectural flaws (e.g., a standard user holding direct AWS Admin permissions without a group wrapper).
- **Hybrid Score:** These two vectors are weighted and merged into a single `hybrid_risk_score` (0-100), dictating the user's threat tier.

4. Incident Clustering & LLM Analysis

Instead of flooding the dashboard with individual alerts, `incident_generator.py` groups related vulnerabilities.

- **Blast Radius Calculation:** High-risk identities sharing similar permission paths or violating the same framework are clustered into specific incidents (e.g., "Privilege Escalation Activity").
- **Groq Integration:** The raw JSON metadata of these clusters is passed to a Groq-powered LLM. The LLM translates the telemetry into a human-readable executive summary and root-cause analysis, formatted in Markdown, which is then dumped into `risk_report.json` and `clustered_incidents.json`.

5. API & Client Frontend

The backend (`app.py`) serves the processed JSON data via REST endpoints to a vanilla JavaScript frontend (`app.js`, `index.html`).

- **Risk Directory & Heatmap:** Provides a cross-platform matrix filtering users by department and integration (AD/AWS/Okta), highlighting density and average risk scores.
- **Vis.js Graph Explorer:** Queries the backend for a specific user's localized graph. The frontend utilizes the Vis.js library to render a hierarchical, interactive node map, allowing security teams to visually trace exactly how an employee achieves a specific permission.
- **Remediation Console:** Allows users to view the LLM-generated incident narrative and execute a simulated POST request (`/api/remediate/{id}`) that simulates applying least-privilege controls and recalibrating the ML models.

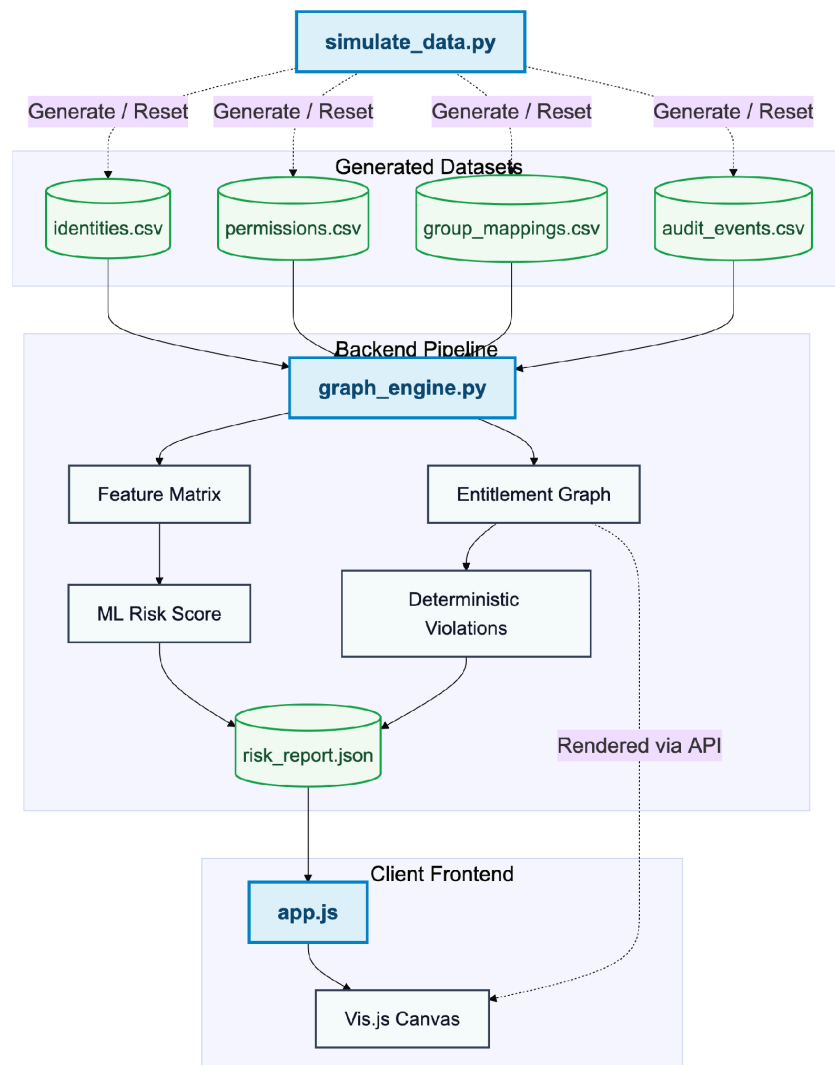


Figure: SprawlBlock High-Level System Architecture & Data Flow Pipeline

Module Descriptions

- **1. Simulation Engine (simulate_data.py):** Generates realistic synthetic datasets (`identities.csv`, `permissions.csv`, `group_mappings.csv`, `audit_events.csv`) containing specific injected anomalies such as orphaned account gaps (12%), over-privileged marketing users (8%), and token abuse (4%).
- **2. Graph Engine (graph_engine.py):** Utilizes `networkx` to build a directed acyclic graph (DAG) representing the enterprise-wide entitlement landscape. It provides functions to traverse paths and resolve downstream group nesting and platform permissions.
- **3. Risk Scorer (risk_scorer.py):** Consolidates structural graph traversal and behavioral event streams into a Pandas DataFrame. It trains an Isolation Forest to score behavioral outliers and maps explicit policy failures (like dormant administrators or off hours spikes) to key regulatory compliance frameworks (NIST SP 800-53, MITRE ATT&CK, GDPR, CIS).
- **4. Incident Engine (incident_generator.py):** Groups identities exceeding a hybrid risk score of `65.0` into logical Incident Clusters. It interfaces with the official **Groq Python SDK** to query `llama-3.3-70b-versatile` to produce natural language executive summaries and copy-pasteable remediation CLI/PowerShell commands.
- **5. REST API & Web App (app.py):** Houses the Flask routing system. It exposes programmatic API endpoints and manages remediation playbooks (e.g. running scripts to revoke access, updating the backend state, and reloading the dashboard).
- **6. Frontend Dashboard (index.html & app.js):** A responsive dashboard styling a premium dark mode, real-time counters, interactive Vis.js graphs, department matrix heatmaps, list filtering, and inline shell terminals to run remediation sequences.

2. Graph Entitlement Schema

To trace nested group permissions and cross-platform sprawl, SprawlBlock constructs a unified graph mapping human root identities to their technical access paths:

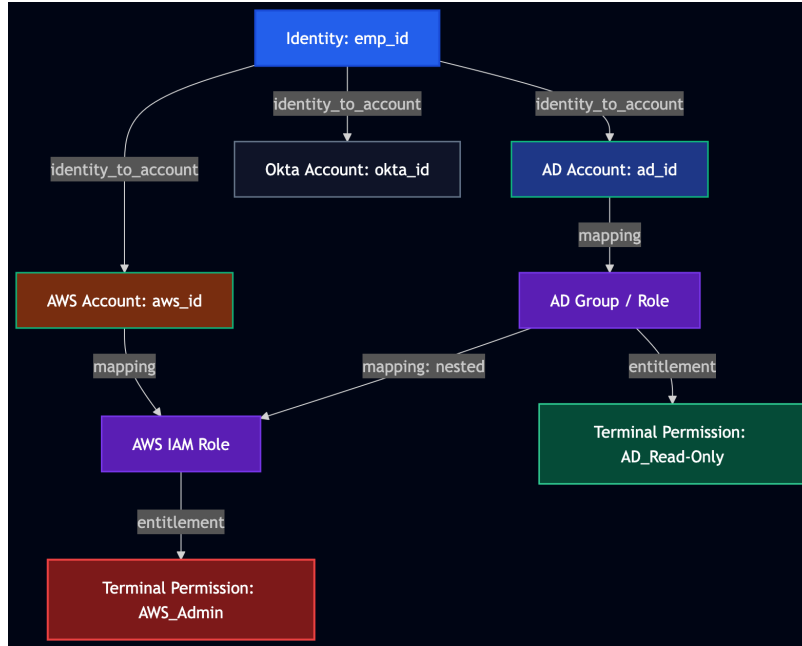


Figure: Unified Identity Entitlement Graph Schema Mapping Access Path

3. Analysis & Risk Scoring Algorithm

SprawlBlock combines unsupervised machine learning with deterministic security rule matchings to create a single unified, action-oriented **Hybrid Risk Score**.

Step 1: Feature Engineering & The Privilege-to-Usage Ratio

For every root human identity (i), behavioral metrics are compiled from audit logs, and structural metrics are calculated via Graph BFS/DFS traversal:

- **Access Frequency (F_i):** Total count of logged audit events associated with any of i's platform accounts.
- **Platform Spread (S_i):** Number of unique platforms (AD, AWS, Okta) from which i has initiated events.
- **Total Privileges (P_i):** The count of terminal permission nodes reachable in the Entitlement Graph from i (number of terminal permission nodes reachable).
- **Privilege-to-Usage Ratio (R_i):** Meant to represent 'Least Privilege' compliance. A high ratio indicates an over-privileged account that holds access it rarely uses. If a user is inactive (F_i = 0), the ratio is explicitly set to 0.0 to avoid division by zero and synthetic outliers skewing the ML model:

$$R_i = P_i / F_i \quad (\text{if } F_i > 0, \text{ else } 0.0)$$

Step 2: Unsupervised Machine Learning (Isolation Forest)

An **Isolation Forest** is trained to establish baseline behavioral boundaries and calculate an outlier score.

1. **Feature Vector:** For each identity, the ML model ingests log-transformed access frequencies and privilege-to-usage ratios to prevent extreme outlier values from dominating the tree splits during training:

```
X_i = [ log(F_i + 1), S_i, log(R_i + 1) ]
```

2. **Training Setup:** Built using `sklearn.ensemble.IsolationForest` with a contamination rate of `0.15` (representing the estimated fraction of anomalies in the system).

3. **Normalization:** The raw anomaly decision score (where lower numbers signify high anomaly probability) is inverted and scaled using `MinMaxScaler` to produce a baseline **ML Risk Score** (M_i) in the range `[0, 100]`.

Step 3: Deterministic Compliance Penalties

Simultaneously, the engine runs heuristic checks to catch explicit policy violations, mapped directly to security controls:

- **Orphaned Account & Lifecycle Gaps (NIST AC-2 / CIS 5):** Human status is `Terminated` in the HR database, but one or more mapped platform accounts are still marked as `Active` in AD, AWS, or Okta. (Penalty: +25 points)
- **Dormant Administrator (NIST AC-2 / CIS 5):** User's last login date exceeds 30 days, yet they retain active `Admin` permissions on one or more platforms. (Penalty: +25 points)
- **Credential Abuse & Token Misuse (MITRE T1078 / MITRE T1550):** Audit logs show suspicious access flags such as `API_Call_From_Suspicious_IP` or `Use_Expired-Token`. (Penalty: +30 points)
- **Anomalous Off-Hours Activity (MITRE T1078):** Heavy API activity (spike of 3+ calls) between 1:00 AM and 4:00 AM. (Penalty: +30 points)
- **Privilege Escalation Activity (MITRE T1098):** Logging contains administrative modifications like `AddUserToGroup_DomainAdmins` or `AttachUserPolicy_AdministratorAccess`. (Penalty: +40 points)
- **Excessive Cross-Platform Privilege (NIST AC-6 / GDPR Art 5):** Ratios exceeding the 75th percentile of active, privileged users (floor at 1.0). Flagged if ($M_i > 70$ and $R_i \geq T_ratio$) or $R_i \geq 2.0$. (Penalty: +20 points)

Step 4: Hybrid Risk Combination

The final **Hybrid Risk Score** (H_i) aggregates the machine learning outlier metrics and policy penalties, capped at 100:

```
H_i = min(M_i + Sum(Compliance Penalties_i), 100.0)
```

4. User Interface Design & Walkthrough

The SprawlBlock client-side dashboard provides security analysts with a powerful, visually responsive command center to analyze enterprise threat scores and run remediations.

1. Main Dashboard Overview

Displays critical KPIs in real time, including **Total Mapped Identities**, **Active Incidents**, **Critical Threat Clusters**, **Average Platform Risk Score**, and active threat counts. High-contrast charts show incident severity distribution.

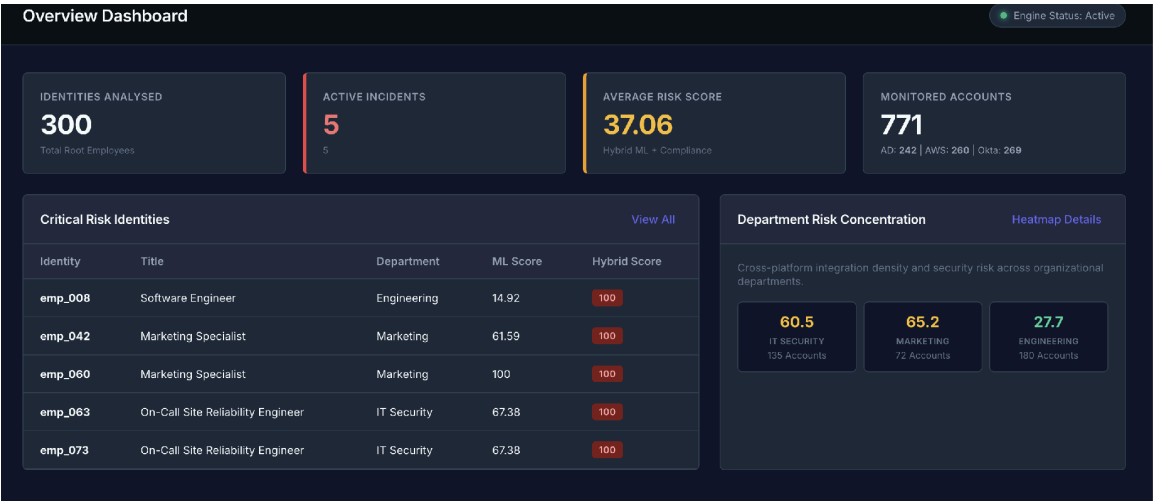


Figure: SprawlBlock Main Security Metrics & Overview Dashboard

2. AI Incident Narratives & Executive Summaries

Selecting an incident displays a detailed 3-paragraph executive summary detailing blast radius, telemetry correlation, and copy-pasteable shell revocation scripts powered by Groq Llama-3.3.

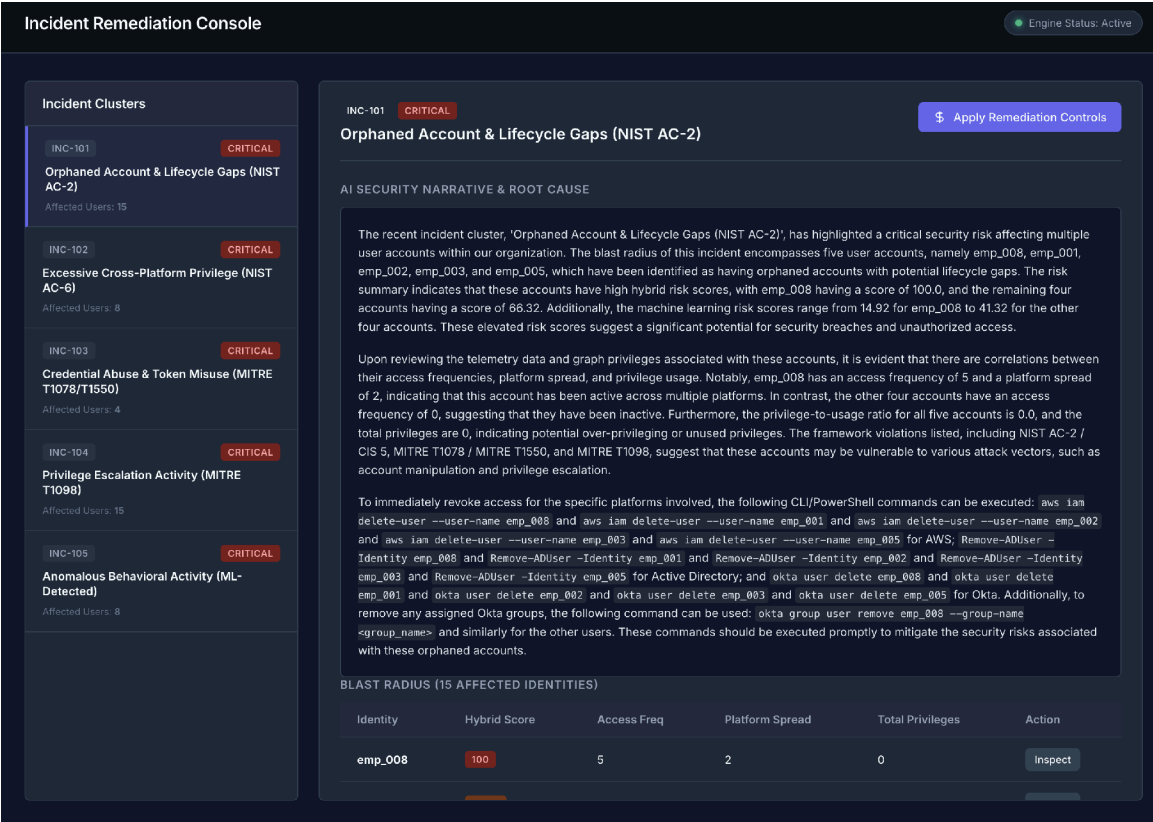


Figure: AI Executive Summary & Blast Radius Drilldown

3. Global Identity Risk Registry

A searchable database displaying every user's Department, Active Directory Status, AWS Status, Okta Status, and computed Hybrid Risk Score, filterable by compliance violations.

Identity Risk Directory					
Engine Status: Active					
SEARCH IDENTITY		DEPARTMENT		COMPLIANCE STATE	
Search ID, title, or department		All Departments		No Violations	
Identity ID :	Title :	Department :	Last Login :	ML Risk :	Hybrid Risk Score ▾
emp_065	On-Call Site Reliability Engineer	IT Security	2026-06-19	91.09	91.09
emp_057	Marketing Specialist	Marketing	2026-06-10	88.16	88.16
emp_070	On-Call Site Reliability Engineer	IT Security	2026-06-11	84.69	84.69
emp_074	On-Call Site Reliability Engineer	IT Security	2026-06-11	84.69	84.69
emp_286	Employee	Finance	2026-06-21	80.79	80.79
emp_116	Employee	HR	2026-06-17	73.84	73.84
emp_104	On-Call Site Reliability Engineer	IT Security	2026-06-16	71.77	71.77
emp_061	On-Call Site Reliability Engineer	IT Security	2026-06-13	70.33	70.33
emp_133	Employee	Sales	2026-06-18	61.02	61.02
emp_202	Employee	HR	2026-06-13	61.02	61.02
emp_200	Employee	HR	2026-06-21	59.04	59.04
emp_209	Employee	Finance	2026-06-14	59.04	59.04
emp_039	Marketing Specialist	Marketing	2026-06-21	58.2	58.2
emp_046	Marketing Specialist	Marketing	2026-06-12	58.2	58.2
emp_089	On-Call Site Reliability Engineer	IT Security	2026-06-14	58.2	58.2
Showing 1-15 of 230					Previous Next

Figure: Global Identity Threat Registry with Framework Filters

4. Identity Detail Panel & Audit Trails

Clicking an identity opens a slide-out drawer displaying the employee's title, department, manager, and their individual ML vs. Hybrid score along with detailed chronological audit trails.

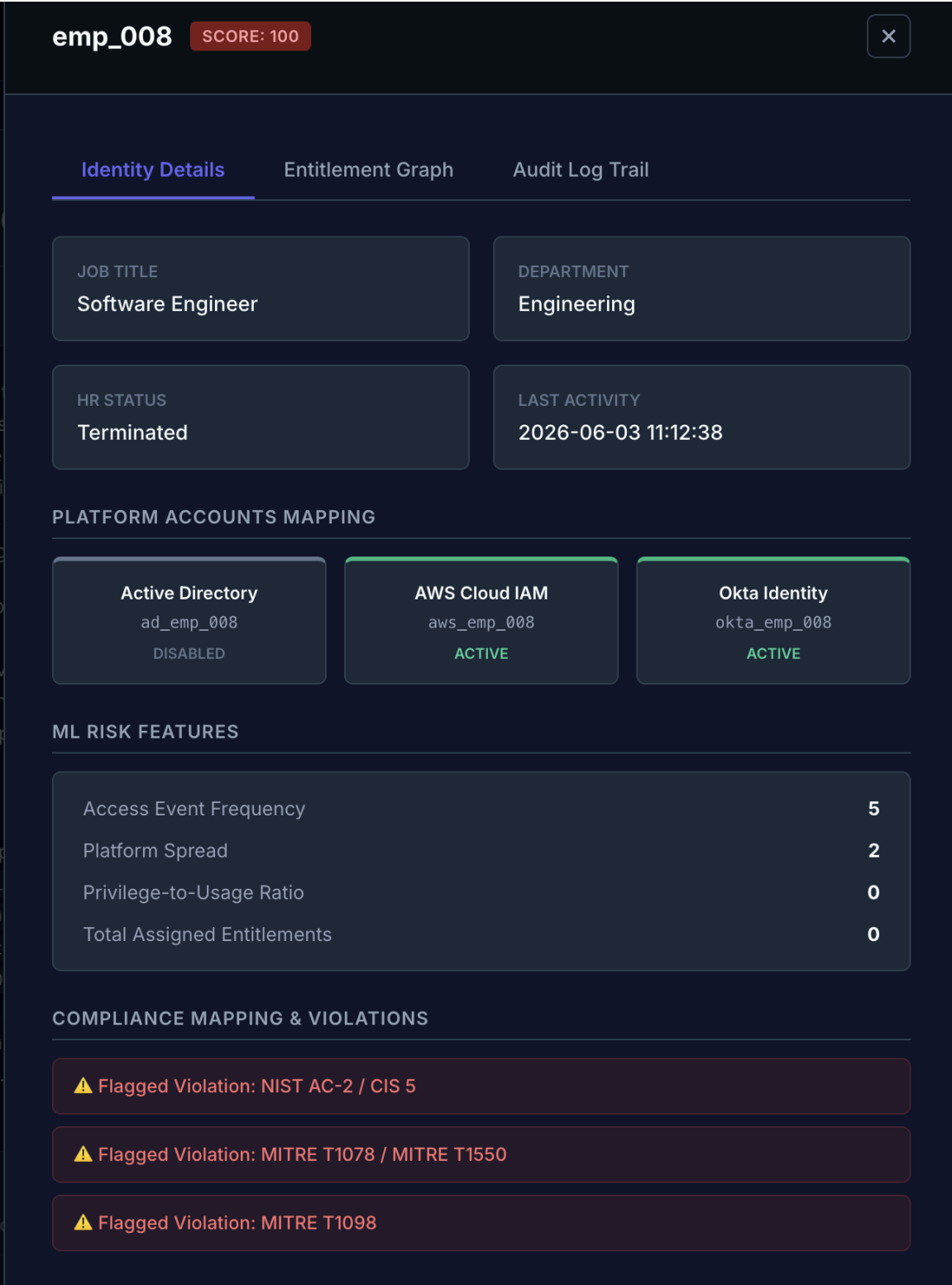


Figure: Identity Entitlement & Behavior Metrics Panel

emp_008

SCORE: 100

×

Identity Details

Entitlement Graph

Audit Log Trail

Timestamp	Platform	Account ID	Action Logged
2026-06-17 20:15:38	AWS	aws_emp_008	Use_Expired_Token
2026-06-04 17:38:38	Okta	okta_emp_008	GrantAdminRole
2026-05-28 07:34:38	Okta	okta_emp_008	UpdateProfile
2026-05-26 15:15:38	AWS	aws_emp_008	AttachUserPolicy_AdministratorAccess
2026-05-25 23:41:38	AWS	aws_emp_008	DescribeEC2Instances

Figure: Chronological Multi-Platform Audit Log trail

5. Interactive Entitlement Mapping Graph

Displays the user's multi-platform access path. Hovering or clicking on a node (Identity, Account, Group, or Terminal Permission) loads granular metadata inside the inspector panel.

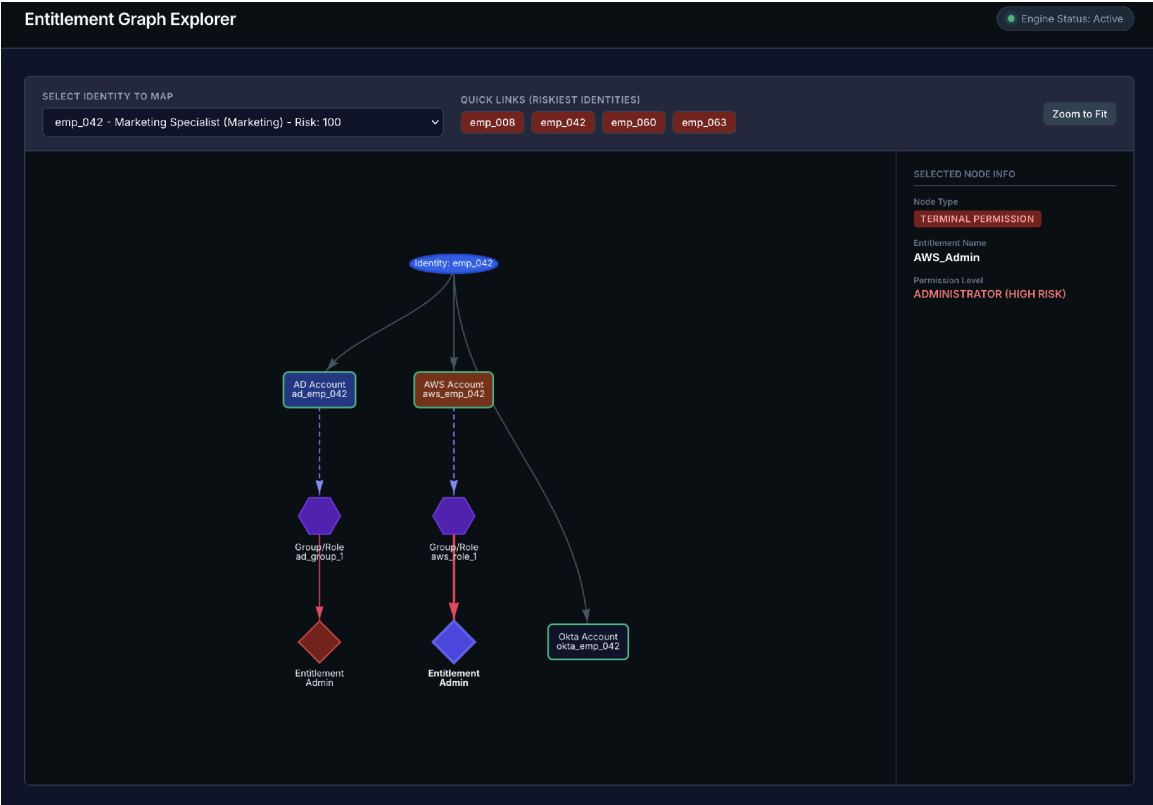


Figure: Vis.js Interactive Downstream Entitlement Tree

6. Heatmap Department Matrix

Color-codes platform risk (AD, AWS, Okta) across business departments (IT, Sales, HR, Marketing) using a smooth green-to-red gradient, allowing matrix-coordinate drilldowns.

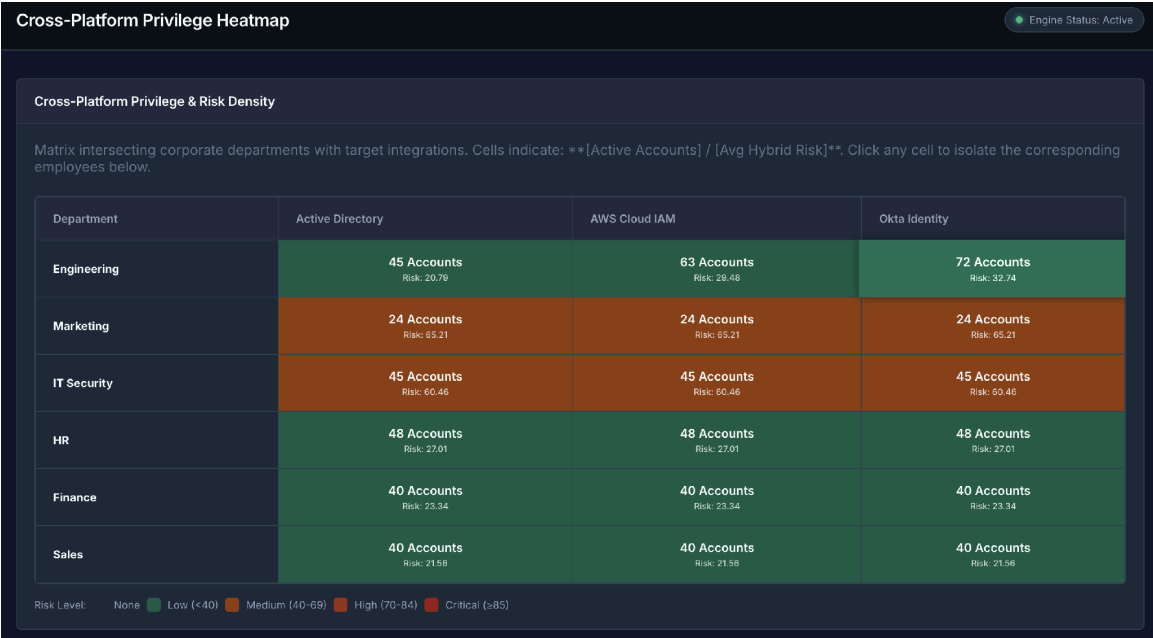


Figure: Department Matrix Risk Concentration Heatmap

7. Automated Remediation Playbooks

Clicking 'Execute Automated Remediation' opens a modal dialog running live API instructions (e.g. revoking AWS permissions, disabling AD logins) with simulated console outputs.

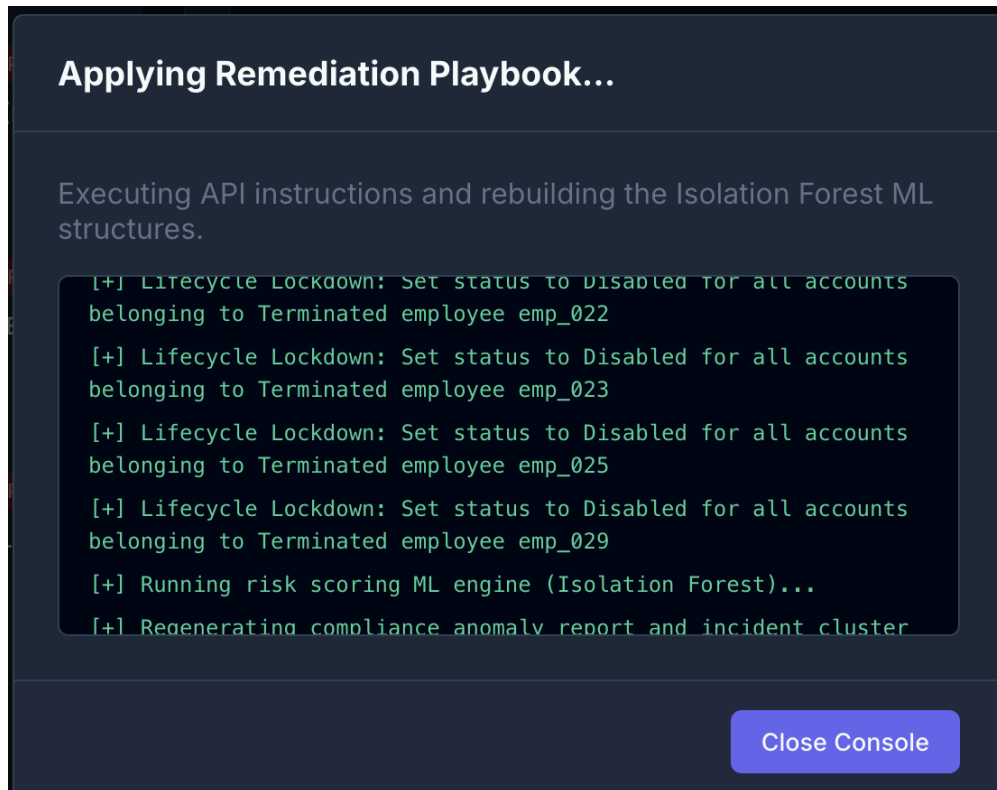


Figure: Live Automated Remediation Modal Console Console